Real-Time Detection of Lateral Movement in Cloud VPC Networks via Graph-Based Analysis

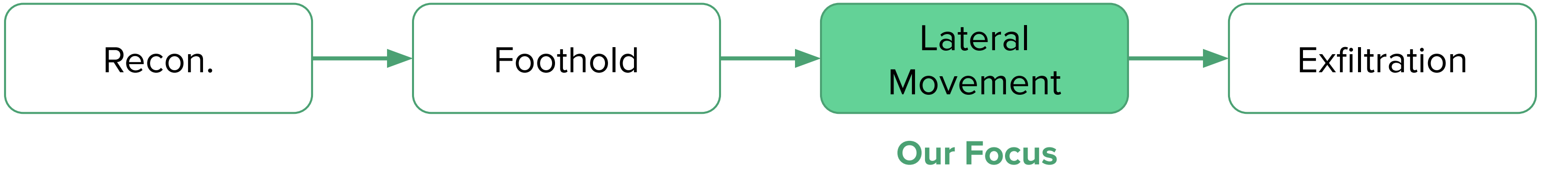
Real-Time Detection of Lateral Movement in Cloud VPC Networks via Graph-Based Analysis

- Lateral movement in cloud networks is hard to detect

- To solve this, we propose modeling network traffic as graphs, and scoring paths / subgraphs to flag suspicious activity

- Real-world data contains enough logs / information to make our approach viable, based on preliminary results

What is Lateral Movement in Cloud Networks?



- VPC (Virtual Private Cloud) - isolated, secure network within a cloud environment where resources can communicate internally

- Lateral Movement - attacker starts to ‘infect’ other machines on the same VPC

Kill-chain framework: Hutchins et al. (2011).

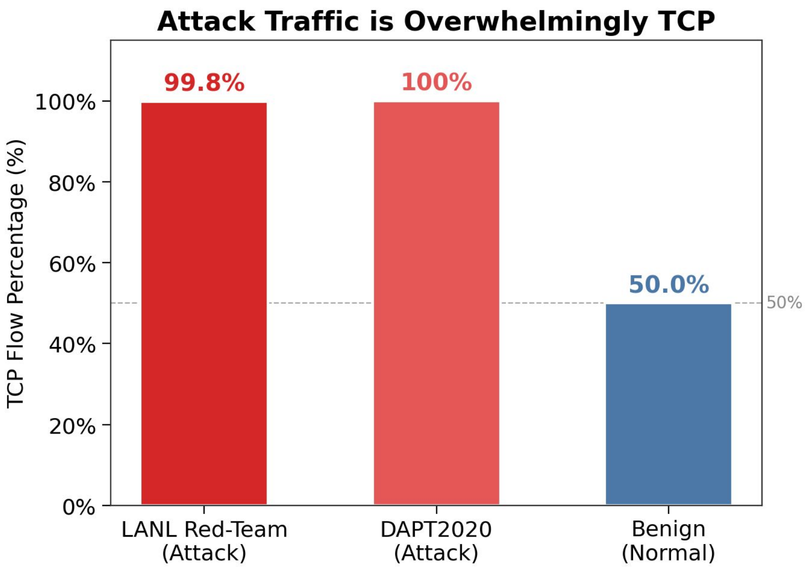
Lateral Movement is Hard to Detect

- Internal VPC traffic is implicitly trusted
    - Security is focused on attackers from the outside, rather than inside
- High traffic volume
    - Billions of normal events daily, all it takes is 1 bad event to slip through for issues to occur
- Fragmented logs
    - Flow logs - show connections, but not who / how auth was given
    - Auth logs - does not show intra-network activities

Datasets - Real-World and Simulated Attack Data

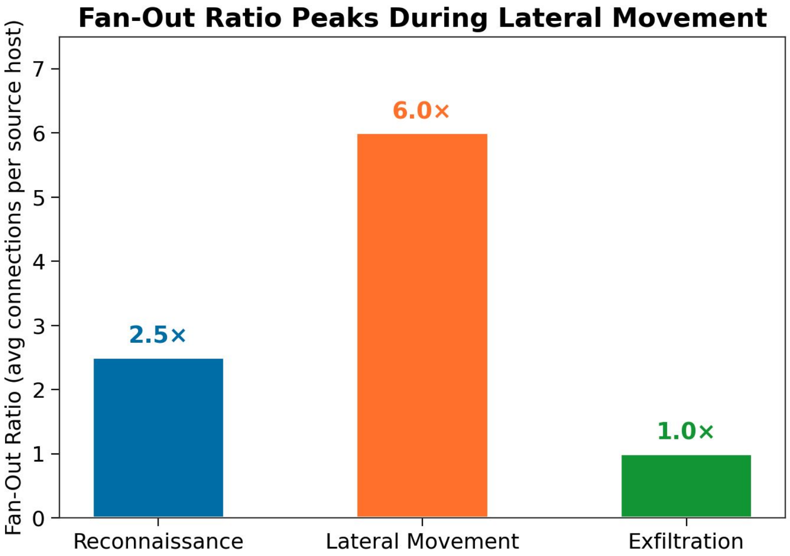
	LANL-Dataset-2015	DAPT2020
Type	Real enterprise network	Simulated APT Testbed
Capture Period	58 days	5 days
Network Size	1.6B+ events total	20,665 attack flows
Attack Ground Truth	749 labeled “red-team” events	Per-flow labels for 4 kill-chain
Log Sources	Flows & Auth & DNS & Processes	PCAP Derived Flows & System logs

Analysis of Data - Traffic Protocols



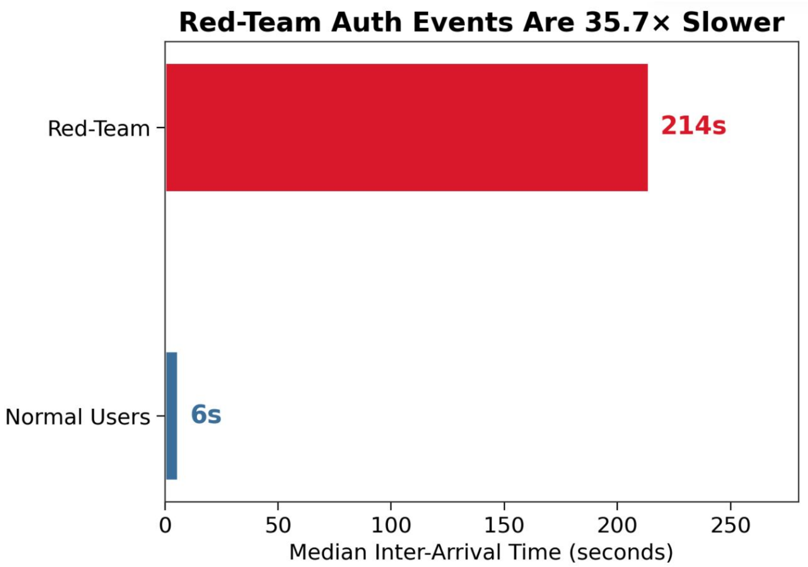
- 99.82% of LANL red-team flows and 100% of DAPT2020 attack flows use TCP
    - HTTP/3 uses UDP instead of TCP (since 2021)!
        - Interesting to see if the data has changed since then.

Analysis of Data - Fan-out Ratio



- Unlike benign traffic which is ~50% TCP, Fan-out ratio increases from 2.50 (reconnaissance) to 6.0 (lateral movement), then drops to 1.0 (exfiltration)

Analysis of Data - Inter-Arrival Time



- Red-team authentication events have median inter-arrival time of 214 seconds vs 6 seconds for normal users (35.7x difference)

We Model Network Traffic as Graphs

Nodes

Computers (IP address), Users (accounts)

Edges

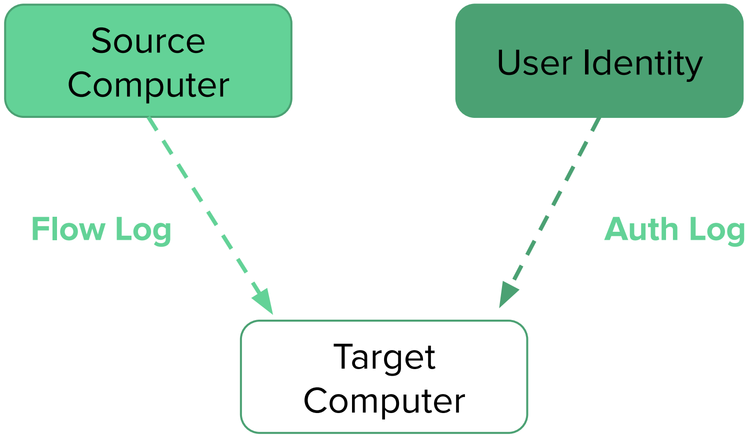
Network connections from flow logs and authentication events

Features (per Edge)

Explained in the next slide

2 sources of Log Input:

- Flow data alone misses who logged in
- Authentication data misses recon.



29 Features per Edge Extracted!

Edge-level (15) - computed per connection

- Structural: edge_rarity (1/weight), src_out_degree, dst_in_degree, source_fan_out, weight_norm, is_self_loop, is_user_edge
- Auth-specific: is_ntlm, is_network_logon, is_success_auth
- Flow-specific: is_unusual_dst_port, protocol_rarity, byte_per_packet, duration_zscore
- Temporal: temporal_decay_weight (exp decay from most recent event)

Node-level (9) - per host

- Structural: in_degree, out_degree, total_degree, fan_out_ratio, betweenness_centrality
- Temporal: inter_arrival_mean, inter_arrival_std, burst_score, active_duration

Graph-level (5) - per network snapshot

- density, average clustering coefficient, component count, node count, edge count

Comparison Baselines (NOT IMPLEMENTED YET)

- “Isolation Forest” - https://ieeexplore.ieee.org/abstract/document/4781136
    - Built-into sklearn

- “One-Class SVM”
    - Built-into sklearn

- After feature extraction, we have DataFrame objects -> chucked into baselines

Scoring Graph Regions Flags Anomalous Behavior

- Score nodes/edges based on feature deviation from baseline
  - Flag subgraphs above threshold

- Three scoring variants:
  - Flow only
  - Auth only
  - Combination

- Only 3 features per log-type considered (FOR NOW, will tweak later):
  - Auth: is_nltm, is_network_logon, edge_rarity
  - Flow: is_unusual_dst_port, protocol_rarity, edge_rarity

VERY Initial Results on LANL Dataset

Method	Recall	FPR	AUC
Graph approach utilizing Logs			
combined	0.662	0.020	**0.954**
auth_only	0.747	0.030	0.951
flow_only	0.013	0.030	0.579

Auth_only_score = is_ntlm (w=0.4) + is_network_logon (w=0.3) + edge_rarity (w=0.3)

Flow_only_score = edge_rarity (w=0.4) + is_unusual_dst_port (w=0.3) + protocol_rarity (w=0.3)

Combined = 1.5*auth_only_score + flow_only_score

Future Plans

- Due to the amount of features, impossible to abelation all of them
  - We will pick up to 3-5 total features per flow_type to narrow down this experiment further
  - Compare them with the baseline directly, so the feature types are the same across both.

- Tweak weight amounts (per flow-type, combined, baseline)

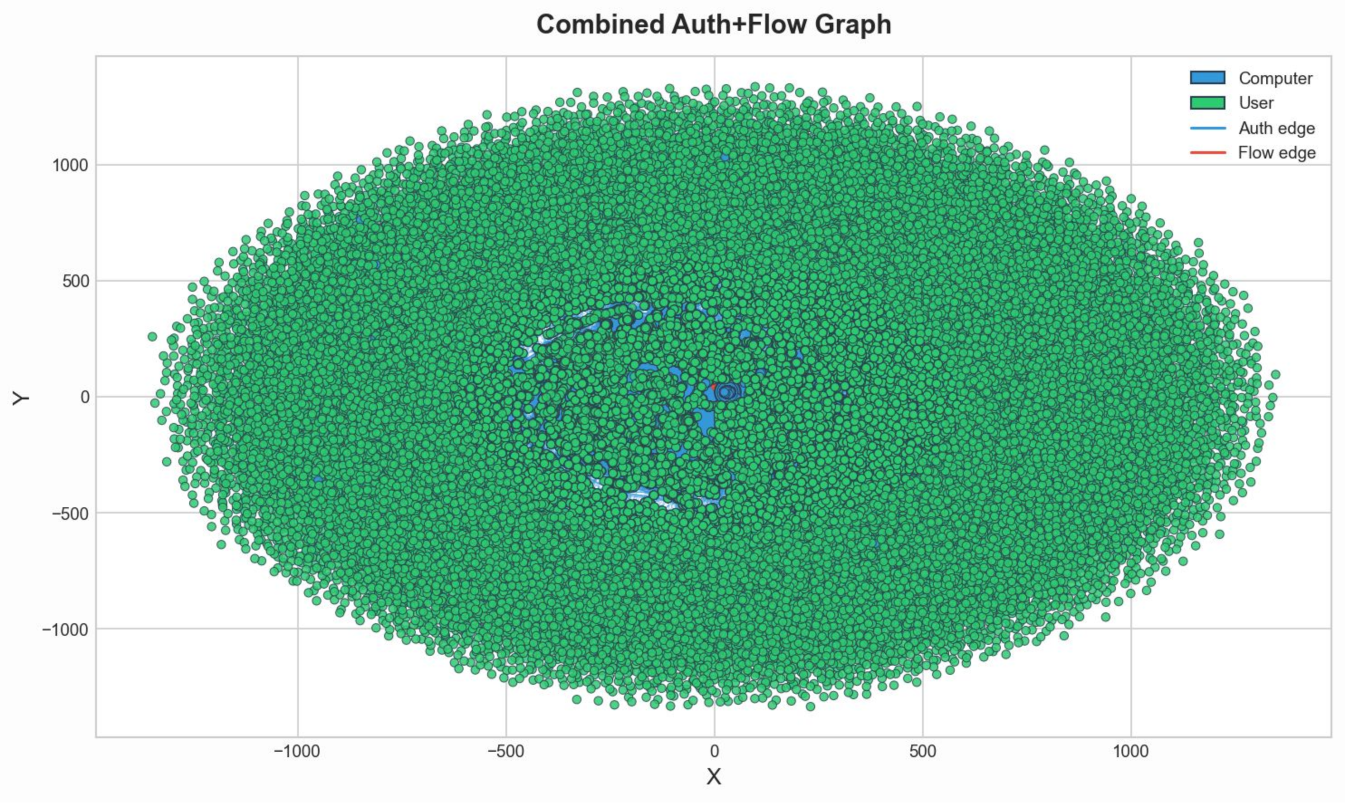
- Statistical significance testing

- Calculate computation cost (cpu usage, memory, time)

Graph-based Analysis Is Useful!

- Lateral movement in cloud networks is hard to detect, but not impossible
- Modeling network traffic as graphs, and scoring paths / subgraphs to flag suspicious activity is a viable approach
- Initial findings on datasets show our approach can work.

Figure that looks cool but is likely useless



Feedback Acknowledgement / Implementations

- The titles of the slides can be somewhat more explanatory of what the slide proves/shows. For example, “Graph Scoring” is not extremely detailed and is somewhat unclear on what the slide is actually trying to tell the viewer.
    - **All titles of the slides are updated to better reflect this as much as possible**
- The presentation is too fast at times, slowing down could help. Especially go over the introduction / background
    - **Background is now split up into 2 slides, more easy-to-digest format**
    - **Trimmed out content that could be unecessary**
- Better time-management / overviews
    - **We paced ourselves better, and tried to ‘dumb-down’ the content to reduce unecessary complications**
- **We updated the introduction of the paper to go more in-depth on the background, instead of creating a separate background section further down**